LIGA ACADÊMICA DE COMPUTAÇÃO EM NUVEM · UNIFAL-MG

Segurança na Nuvem AWS

Domínio 2 — Security & Compliance · CLF-C02 (30% da prova)

Outubro 2026

O que vamos ver

Domínio 2 — 30% da prova · IAM, Criptografia, Proteção de Rede e Detecção

PARTE 1

- Responsabilidade Compartilhada
- IAM — Usuários, Grupos, Políticas, Roles
- Security Groups vs NACLs

PARTE 2

- KMS — Criptografia e Chaves
- Shield — Proteção DDoS
- WAF · Inspector · GuardDuty · Macie

PARTE 1 · TÓPICO 01

Responsabilidade Compartilhada

A divisão fundamental de segurança na nuvem

Modelo de Responsabilidade

Condomínio: AWS cuida do prédio, você cuida do seu apartamento

AWS — Segurança DA nuvem

"Security OF the cloud"

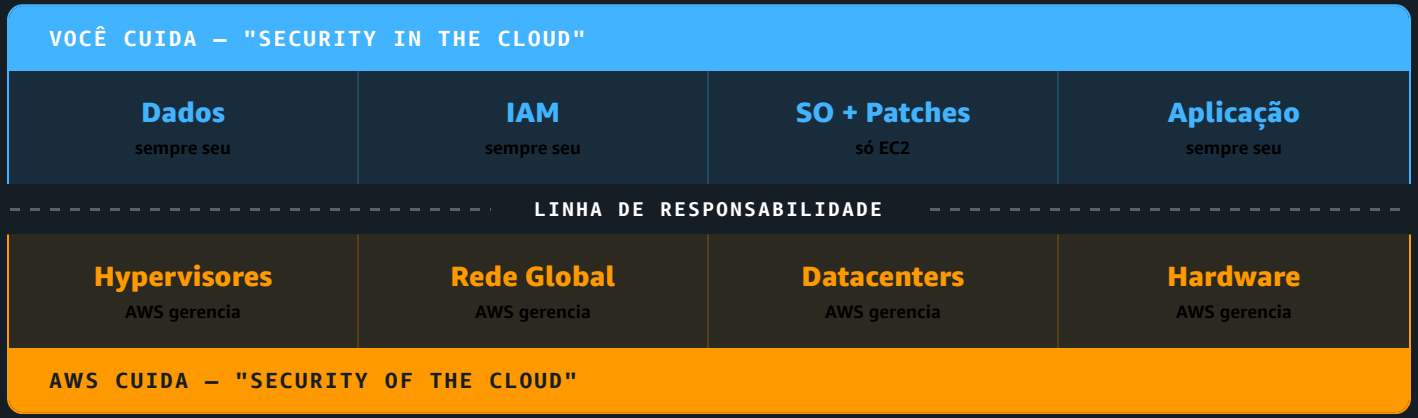
- Hardware dos servidores
- Datacenters e segurança física
- Rede global e hypervisors
- Infraestrutura gerenciada (RDS, Lambda, S3)

Você — Segurança NA nuvem

"Security IN the cloud"

- Seus dados e criptografia
- IAM — controle de acesso
- SO e patches (no EC2)
- Configurações de rede (SG / NACL)

GUARDE ESSA IMAGEM — ELA RESPONDE METADE DAS QUESTÕES SOBRE RESPONSABILIDADE



Regra de ouro: Dados e IAM são **sempre seus**, em qualquer serviço. EC2 = você gerencia o SO. RDS/Lambda = AWS gerencia o SO.

A divisão muda com o serviço

Quanto mais gerenciado, menos você cuida — mas dados e IAM são sempre seus

RESPONSABILIDADE	EC2 (IaaS)	RDS (PaaS)	Lambda	S3 / SaaS
Hardware físico	AWS	AWS	AWS	AWS
Sistema Operacional	Você	AWS	AWS	AWS
Patches do SO	Você	AWS	AWS	AWS
Aplicação / código	Você	Você	Você	Você
Dados e IAM	Você	Você	Você	Você

Regra de ouro: **se você pode configurar no console da AWS, é sua responsabilidade**

PARTE 1 · TÓPICO 02

IAM

Identity and Access Management · Quem pode fazer o quê

AWS IAM

Sistema de crachás da empresa — cada identidade tem suas permissões

- **Global — não é por região**
- **Gratuito — zero custo por usuários ou políticas**
- **Default Deny — tudo negado até conceder explicitamente**
- **Root user — acesso total, nunca use no dia a dia**



COMO AS PEÇAS DO IAM SE CONECTAM — GUARDE ESSE MAPA



Policies — Deny > Allow

Um único Deny explícito cancela todos os Allows

PRIORIDADE DE AVALIAÇÃO

1° Explicit Deny
SEMPRE vence. Nada passa.

2° Explicit Allow
Concede se não há Deny.

3° Default Deny
Sem policy → tudo negado por padrão.

Na prova: Allow S3 no grupo + Deny S3 na policy pessoal → Deny vence.

IAM ROLES — POR QUE USAR?

Sem senha permanente — credenciais temporárias

EC2 acessa S3 → attach role, sem Access Key hardcoded

Lambda executa → role de execução automática

Cross-account → role assumida por outra conta

User: pessoa com senha permanente
Role: capacete que qualquer serviço veste temporariamente

MFA + Boas Práticas

Pilares IAM mais cobrados no CLF-C02

Root user

Ative MFA imediatamente. Nunca use no dia a dia. Só setup e billing.

Least Privilege

Dê só a permissão necessária. Nunca AdministratorAccess para quem precisa de S3.

Roles para serviços

Nunca Access Key hardcoded no código. Prefira roles — chaves no código vazam em repositórios.

Um user por pessoa

Nunca compartilhe credenciais. Rastreabilidade — saber quem fez o quê.

Rotacione Keys

Rotacione Access Keys periodicamente. Minimiza janela de exploração se vazar.

MFA obrigatório

Segundo fator para root e admins. Senha vazou? Sem MFA, sem acesso.

PARTE 1 · TÓPICO 03

SG vs NACLs

Dois firewalls, duas camadas — essa comparação CAI na prova

Security Group vs NACL

NACL = guarita na entrada da rua · SG = tranca da sua porta

Security Group

- Nível de **instância** (EC2, RDS...)
- Somente regras de **Allow**
- **Stateful** — resposta volta automaticamente
- Avalia **todas** as regras juntas
- Pode referenciar outro SG

Não bloqueia IP específico

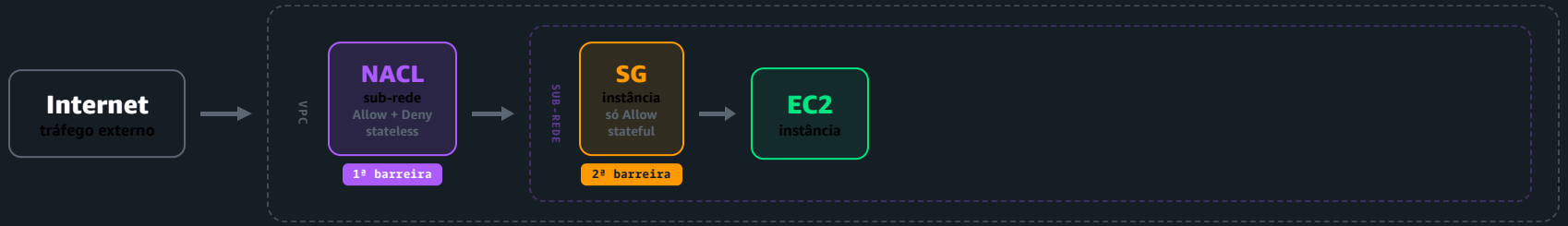
Network ACL (NACL)

- Nível de **sub-rede** — aplica a todos
- Regras de **Allow e Deny**
- **Stateless** — precisa de regra de ida E volta
- Avalia em **ordem numérica** (para na 1ª match)
- Tráfego passa pelo NACL PRIMEIRO

Bloqueia IP específico com Deny

Na prova: "Bloquear IP em toda a sub-rede" → NACL · "Controle por instância específica" → Security Group

ONDE CADA FIREWALL VIVE — VISUALIZE O FLUXO DO TRÁFEGO



Bloquear IP malicioso na subnet inteira → NACL com regra Deny

Controlar acesso por instância específica → Security Group

Revisão — Parte 1

Palavras-chave que caem na prova

Responsabilidade

OF = AWS · IN = você

EC2 SO patches → você

RDS SO patches → AWS

Dados → sempre você

IAM

Deny > Allow > Default Deny

Role = sem chave fixa, temp.

MFA = obrigatório para root

Least privilege

SG vs NACL

SG = instância, stateful, Allow

NACL = sub-rede, stateless

Bloquear IP → NACL

Referência a SG → Security Group

Uma empresa migrou seu banco de dados para o Amazon RDS. Quem é responsável por aplicar patches de segurança no sistema operacional do banco de dados?

A
O DBA (Administrador de banco de dados) da empresa

B — CORRETO
A AWS gerencia automaticamente os patches do SO

C
O time de DevOps do cliente

D
A empresa e a AWS dividem essa responsabilidade

Por quê B? RDS é um serviço gerenciado — AWS cuida do SO, patches e backups automaticamente. Com EC2, a resposta seria diferente: você gerenciaria o SO.

Um desenvolvedor precisa que sua função AWS Lambda leia arquivos de um bucket S3 com segurança. Qual é a prática recomendada de IAM?

A
Criar IAM User com Access Key e inserir no código da função

B
Usar a conta root para conceder acesso direto ao S3

C — CORRETO
Criar IAM Role com permissão S3 e associar à função Lambda

D
Deixar o bucket S3 público para facilitar o acesso

Por quê C? IAM Roles fornecem credenciais temporárias automáticas — sem chaves fixas. Access Key no código (opção A) é uma vulnerabilidade crítica que vaza em repositórios Git.

PARTE 2 · TÓPICO 01

KMS

Key Management Service — Criptografia de dados em repouso

AWS KMS

Cofre de chaves criptográficas — integrado a 100+ serviços AWS

- **Criptografa S3, EBS, RDS, DynamoDB...**
- **Toda operação registrada no CloudTrail**
- **Envelope Encryption: DEK (dados) + CMK (protege a DEK)**

> **Na prova:** **"Criptografar S3 / EBS / RDS" → KMS**

TIPOS DE CHAVE

AWS Managed Key
AWS gerencia, rotação automática a cada 3 anos

Customer Managed Key (CMK)
Você controla, rotação anual opcional, auditoria total

CloudHSM
Hardware dedicado exclusivo — FIPS 140-2 Level 3

KMS vs CloudHSM: KMS = gerenciado, multi-tenant · CloudHSM = hardware dedicado, FIPS Level 3 — use quando a prova mencionar "FIPS 140-2"

ENVELOPE ENCRYPTION — COMO O KMS PROTEGE SEUS DADOS



Resultado: seus dados ficam cifrados em repouso. Só quem tem permissão KMS consegue decifrar. Cada uso da CMK fica registrado no CloudTrail.

NA PROVA
criptografar = KMS
FIPS Level 3 = CloudHSM

PARTE 2 · TÓPICOS 02 E 03

Shield + WAF

DDoS · SQL Injection · Bots · Rate Limiting

AWS Shield

DDoS = 10.000 robôs no restaurante que trava quando clientes reais chegam

Shield Standard

Gratuito · automático para todos

- **Proteção L3/L4 (volumétrico e protocolo)**
- **Ativado automaticamente em toda conta**
- **Visibilidade básica de ataques**

Sem custo adicional

Shield Advanced

~$3.000/mês por organização

- **L3/L4 + L7 (HTTP)**
- **DDoS Response Team (DRT) 24/7**
- **Reembolso de custo por ataque**
- **Visibilidade detalhada de ataques**

"Equipe especializada DDoS 24/7" → Advanced

AWS WAF

Web Application Firewall — lê o QUE o visitante está pedindo (camada 7)

- **Inspeciona headers, query string, body, IP, país**
- **Bloqueia SQL Injection, XSS, bots, scraping**
- **Rate limiting — ex: > 1.000 req/min por IP → Block**
- **Geo-bloqueio por país**
- **Managed Rule Groups — OWASP Top 10 prontos**

MNEMÔNICO — CAMADAS

WAF — Conteúdo
O que está pedindo · SQL, XSS, bots · L7

Shield — Volume
Quantos estão pedindo · DDoS · L3/L4

SG / NACL — Quem
IP e porta · rede · L3/L4

Uma empresa sofreu um ataque com requisições HTTP maliciosas contendo SQL Injection no corpo da mensagem, que passaram pelo Shield Standard sem serem bloqueadas. Qual serviço deveria ser adicionado?

A
Shield Advanced — versão mais completa do Shield

B — CORRETO
AWS WAF — inspeciona o conteúdo das requisições HTTP (L7)

C
Network ACL com regras Deny para o IP atacante

D
Amazon Inspector — para verificar vulnerabilidades

Por quê B? Shield protege contra DDoS (volume de tráfego, L3/L4). WAF inspeciona o conteúdo das requisições HTTP (L7) e bloqueia SQL Injection, XSS e outros ataques de aplicação.

PARTE 2 · TÓPICO 04

Inspector · GuardDuty · Macie

Três serviços de detecção — cada um olha para uma coisa diferente

Inspector · GuardDuty · Macie

Três serviços de detecção — cada um com foco diferente

Inspector

Infraestrutura · CVE

CVEs em pacotes e SO

EC2, ECR (containers), Lambda

Contínuo e automático

Finding = CVE ID + score CVSS

Médico faz check-up antes do paciente adoecer

GuardDuty

Guarda · Ameaças ativas

Comportamento anômalo (ML)

CloudTrail + VPC Logs + DNS

Acesso suspeito, mineração

Atividade em tempo real

Câmera de segurança + IA que detecta intruso

Macie

Minha privacidade · PII

Dados sensíveis e PII no S3

CPF, cartão, senha expostos

Privacidade e compliance (LGPD)

Palavra-chave: "dados sensíveis S3" → Macie

CADA SERVIÇO OLHA PARA UM LUGAR DIFERENTE — GRAVE ISSO

Inspector
olha para o código

EC2
pacotes instalados

ECR / Lambda
imagens de container

Resultado: CVE encontrada
vulnerabilidade no software

GuardDuty
olha para os logs

CloudTrail
ações na conta AWS

VPC Flow Logs + DNS
tráfego de rede

Resultado: ameaça ativa
comportamento suspeito em tempo real

Macie
olha para os dados

S3 Buckets
conteúdo dos arquivos

CPF · Cartão · Senha
dados pessoais (PII)

Resultado: dado exposto
PII em bucket público ou desprotegido

Inspector = vulnerabilidade no código · GuardDuty = ameaça no comportamento · Macie = dado sensível no S3

O CISO de uma empresa suspeita que arquivos com CPFs e dados de cartão de crédito de clientes foram acidentalmente carregados em buckets S3 públicos. Qual serviço da AWS identificaria esses dados sensíveis automaticamente?

A
Amazon Inspector — escaneia vulnerabilidades em EC2

B
Amazon GuardDuty — detecta ameaças por comportamento

C
AWS Shield Advanced — protege contra DDoS

D — CORRETO
Amazon Macie — detecta PII e dados sensíveis no S3

Por quê D? Macie usa ML para encontrar dados pessoais (CPF, cartão, senha) em buckets S3. Inspector = CVE em código. GuardDuty = comportamento suspeito nos logs. Palavra-chave: "dados sensíveis + S3" → Macie.

LIGA ACADÊMICA DE COMPUTAÇÃO EM NUVEM · UNIFAL-MG

Revisão — Parte 2

- **KMS = criptografia · "FIPS Level 3" → CloudHSM**
- **WAF = SQLi, XSS, bots, rate limit, geo-block (L7)**
- **Shield Standard = grátis · Advanced = DRT 24/7**
- **Inspector = CVE · GuardDuty = ameaças · Macie = PII S3**

Domínio 2 = 30% da prova · Junto com D1 + D3 = 88% cobertos. Bora pro Kahoot!